



TOPIC 1

Cyberspace and Information Security Introduction

Dr. Itzhak Aviv



Part 1

The Cyberspace Landscape

Understanding the digital ecosystem we must protect

What is Cyberspace?

Cyberspace is the interconnected digital environment formed by the global network of computing devices, communication infrastructure, and information systems that enable people, organizations, and machines to interact, exchange data, and conduct operations.

Physical Layer



Cables, routers, data centers, satellites, undersea fiber optics, and all hardware that carries data

Logical Layer



Protocols (TCP/IP, DNS, BGP), software platforms, operating systems, cloud services, and APIs

Social Layer



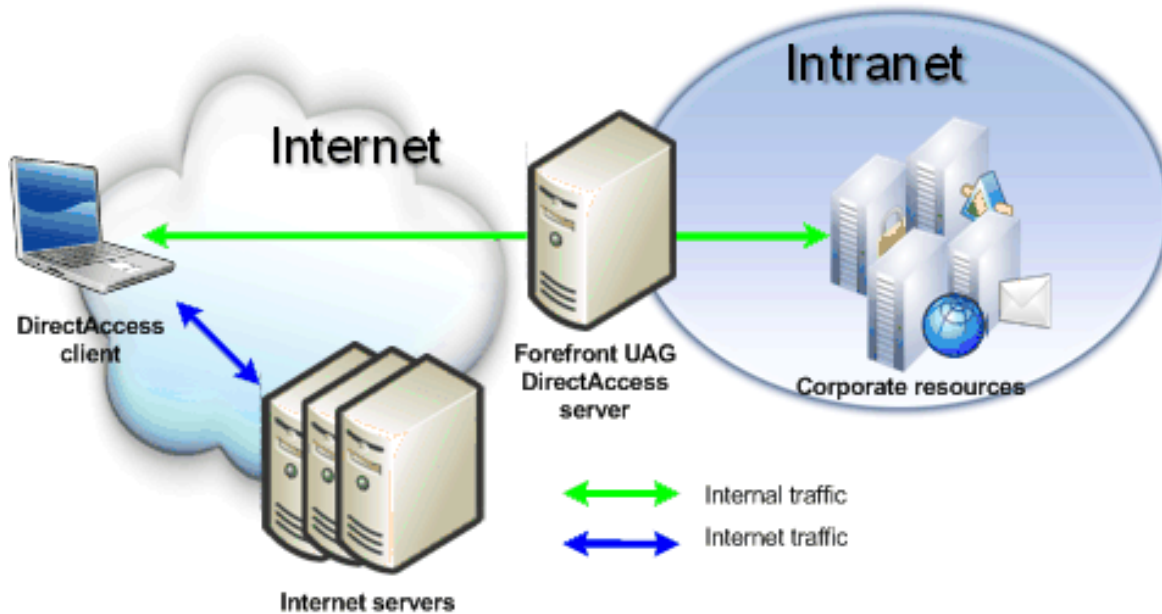
People, digital identities, organizations, online communities, and their behaviors

Governance Layer

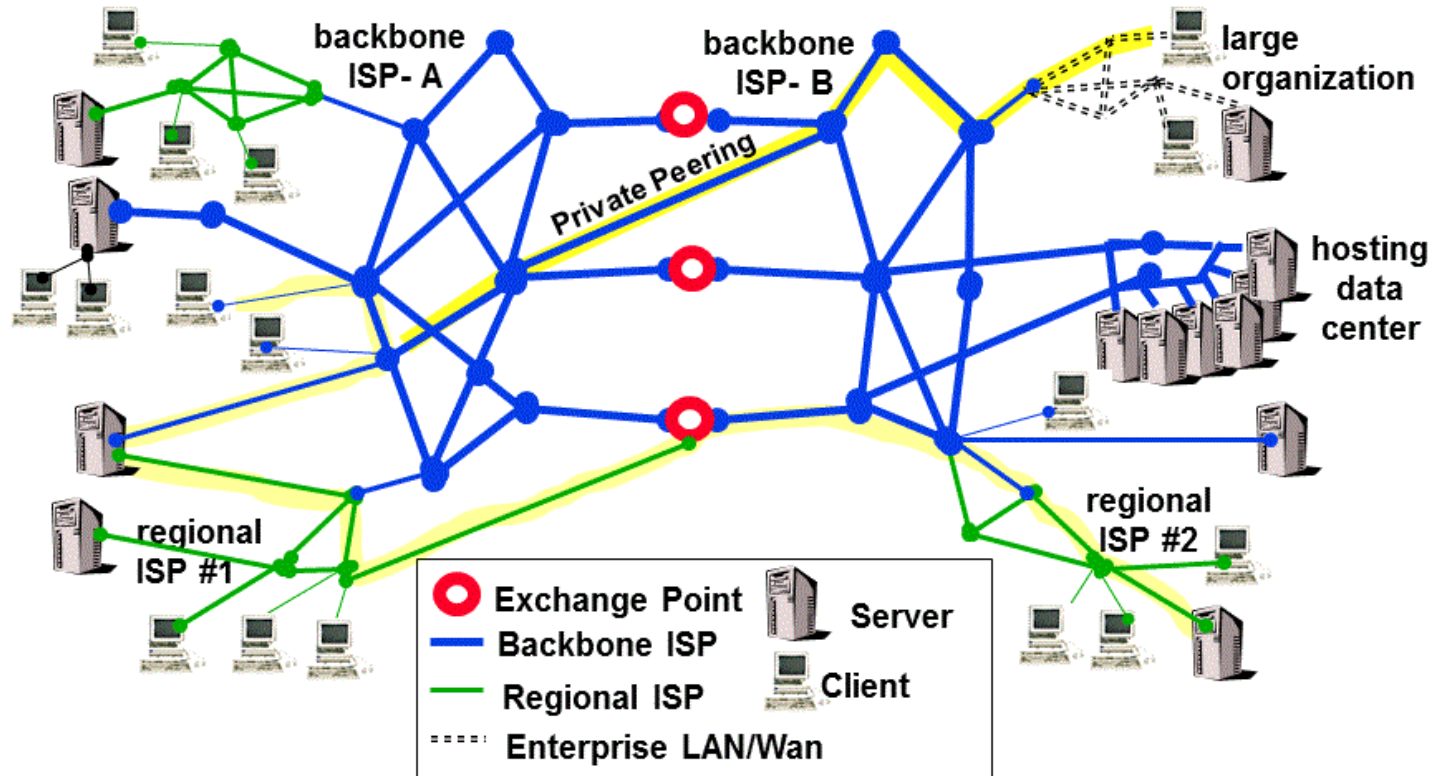


Laws, regulations, policies, standards (ISO 27001, NIST), and international agreements

Introduction to Cyberspace Landscape



Introduction to Cyberspace Landscape



Cyberspace in the Physical World

Modern cities embed digital systems in every aspect of life, creating vast attack surfaces.

Smart Energy



Intelligent grids, smart meters, automated load balancing

Connected Transport



Autonomous vehicles, fleet management, smart traffic signals

Smart Buildings



HVAC automation, access control, security cameras, BMS

e-Government



Digital identity, online services, citizen data platforms

IoT Sensors



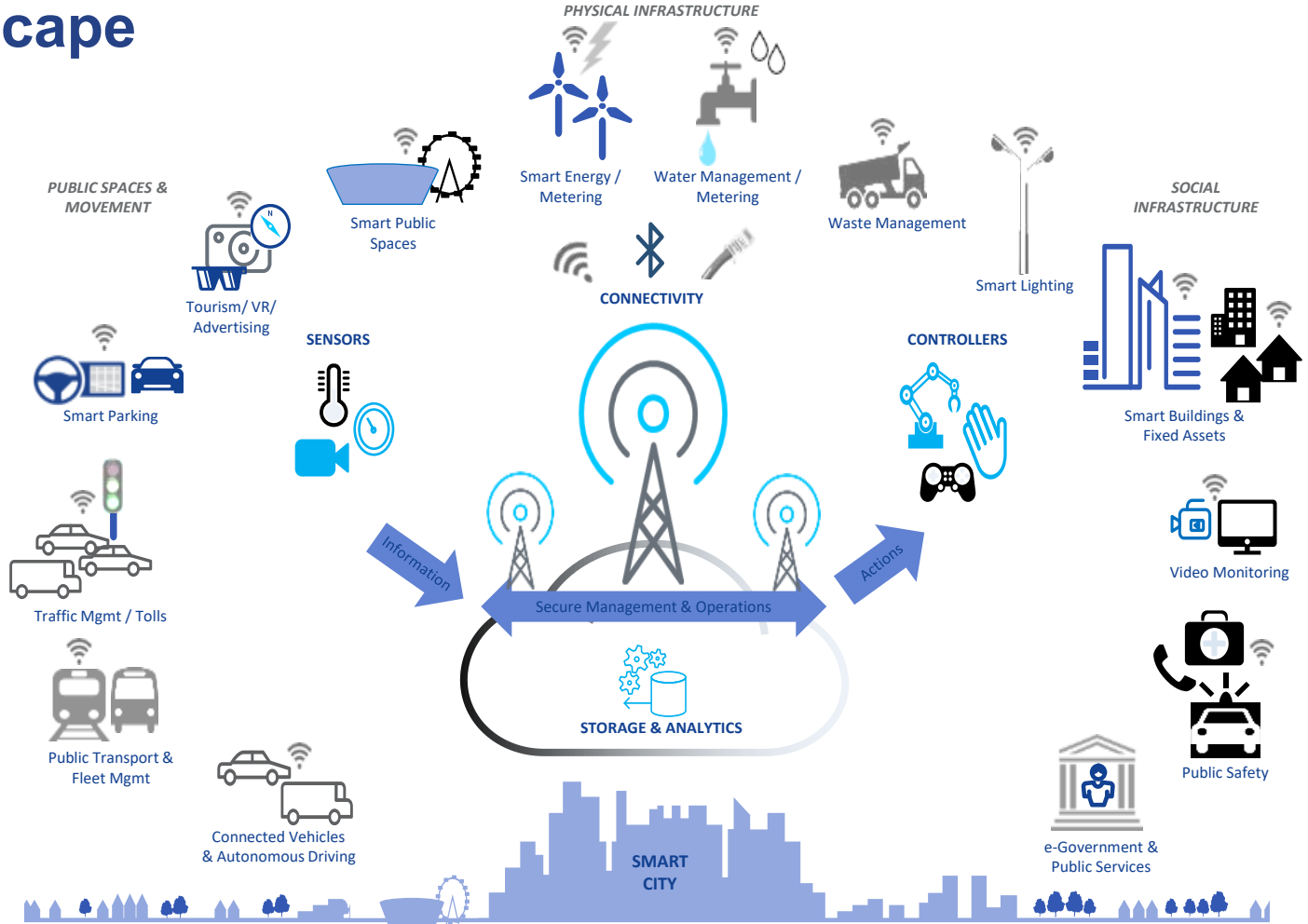
Environmental monitoring, water management, public safety

Cloud Platforms



SaaS/PaaS/IaaS powering city-wide digital operations

Introduction to Cyberspace Landscape



The Evolving Threat and Technology Landscape



AI and Machine Learning

AI powers both defense (anomaly detection, automated response) and offense (deepfakes, adaptive malware, prompt injection)



Cloud-Native Transformation

Workloads shifting to public cloud create shared responsibility models and new misconfiguration risks



5G and Beyond

Ultra-low latency networks expand connectivity but enlarge the attack surface with billions of new endpoints



Confidential Computing

Hardware-based TEEs protect data-in-use, adding a new dimension beyond encryption at rest and in transit



Part 2

The CIA Triad

Confidentiality, Integrity, and Availability — the foundation of information security

Information Security vs. Cybersecurity

Information Security

Information Security

Protects information and information systems so they preserve:

- confidentiality
- integrity
- availability

The focus can be digital information, processes, permissions, policy, and compliance.

Cybersecurity

Cybersecurity

Protects the use of cyberspace against attacks and vulnerabilities.

The focus is often on networks, endpoints, exposed services, identities, adversaries, and incident response.

The CIA Triad

The CIA Triad is the foundational model for information security. Every security control, policy, and design decision can be traced back to protecting one or more of these three properties.



Confidentiality

Ensuring information is accessible only to those authorized to access it



Integrity

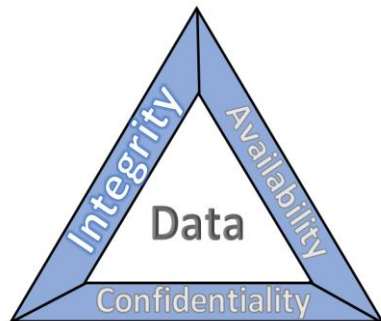
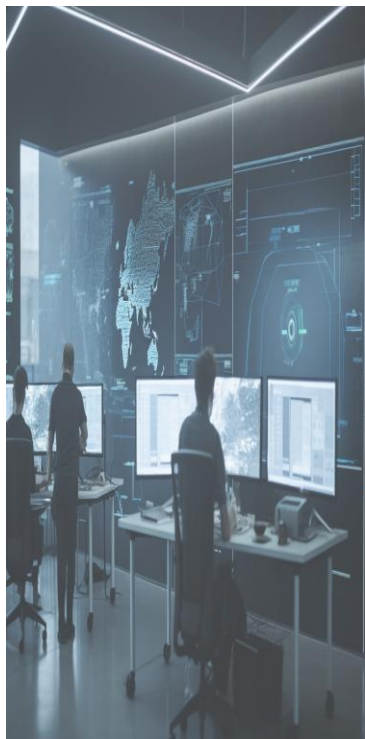
Ensuring data accuracy and completeness, protecting against unauthorized modification



Availability

Ensuring authorized users have reliable, timely access to information and resources

Understanding the Security Triad



Confidentiality – סודיות

0
1

שמירה על כך שמידע יישאר נגיש רק למי שמורשה לראותו. מטרתה למנוע גישה של גורמים לא מורשים לנתונים (כמו האקרים, עובדים זרים, או משתמשים לא מאומתים).

Integrity – שלמות

0
2

הבטחת דיוקו ועקביותו של המידע, שהנתונים והפעולות לא ישונו, לא ייפגמו, ולא יזויפו.

Availability – זמינות

0
3

שמירה על כך שהמערכת והמידע יהיו זמינים ונגישים למורשים בכל עת. המטרה היא למנוע מצבים שבהם תקלה, תקיפה או אסון יגרמו להשבתה.

Confidentiality — who is allowed to see the information?

Examples of sensitive assets

- Grades
- PII
- HR files
- API keys
- Medical records
- Private source code

Common confidentiality failures

- A link open to everyone
- A stolen password
- An exposed bucket
- An email to the wrong recipient
- An overly broad shared drive

Key controls

- Authentication and authorization
- Need-to-know
- Encryption at rest and in transit
- Secrets management
- Data classification
- Access review

Importance of Data Confidentiality



Confidentiality — Protecting Data from Unauthorized Access



Confidentiality ensures that sensitive information is disclosed only to authorized individuals, processes, or systems. A breach of confidentiality can lead to identity theft, corporate espionage, regulatory fines, and loss of trust.

Key Mechanisms



Encryption

AES-256, RSA, TLS 1.3 — protects data at rest and in transit



Access Control

RBAC, ABAC, least privilege principle, MAC/DAC models



Authentication

MFA, biometrics, SSO, passwordless (FIDO2/WebAuthn)



Data Classification

Public, Internal, Confidential, Restricted — governs handling

Integrity — are the data correct, complete, and unchanged without authorization?

What can go wrong?

- Grade changes
- Log deletion
- Invoice fraud
- A malicious code update
- Software supply-chain compromise

How do we protect integrity?

- Hashes and signatures
- Version control
- Input validation
- Separation of duties
- Approval before change
- Audit trail

Questions that guide analysis

- Who changed it?
- When?
- With what permission?
- Can we detect the change?
- Can we restore a previous state?

Integrity — Ensuring Data Accuracy and Trustworthiness



Integrity guarantees that data has not been tampered with, corrupted, or altered without authorization. It applies to data at rest, in transit, and during processing.

Threats to Integrity

Man-in-the-Middle (MitM)

Interception and alteration of data in transit

SQL Injection

Unauthorized modification of database records

Ransomware (destructive)

Encryption or corruption of critical files

Insider threats

Authorized users modifying data maliciously or accidentally

Protection Mechanisms

Hashing (SHA-256, SHA-3) • Digital signatures (PKI) • Checksums • Version control • Audit trails • Input validation

Availability — are the system and data available when needed?

What harms availability?

- Ransomware
- DDoS
- Cloud failure
- A bad update
- A weak supplier dependency
- Human error

Controls that strengthen availability

- Redundancy
- Backups
- Monitoring
- Careful change management
- Recovery planning
- Response exercises

Message for an intro course

A failure that is not “classic cyber” can still be a security event if it breaks trust, service, or operational control.

Availability — Keeping Systems Operational



Availability ensures that authorized users can access data and services when needed. Downtime has direct financial, operational, and reputational consequences.

Redundancy

Duplicate critical components to eliminate single points of failure

Failover and Load Balancing

Automatic switching to backups; distributing traffic across servers

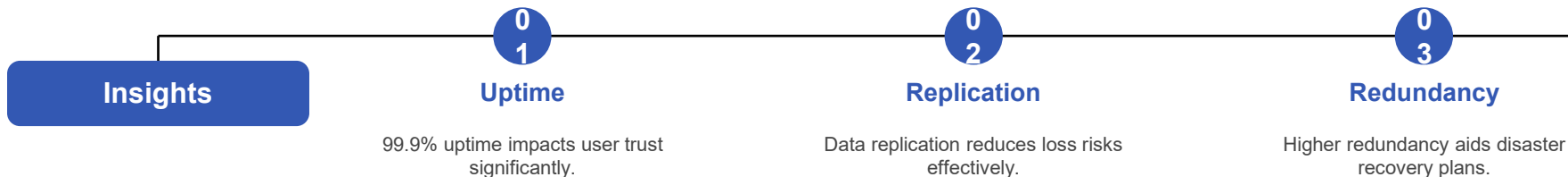
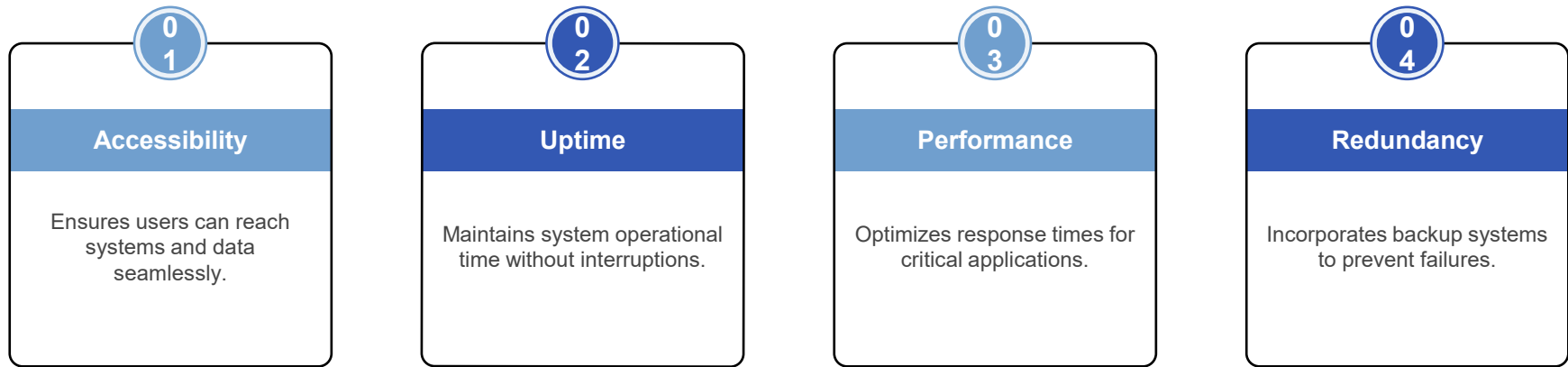
Disaster Recovery (DR)

Documented plans with defined RTO/RPO; regular testing of backup restoration

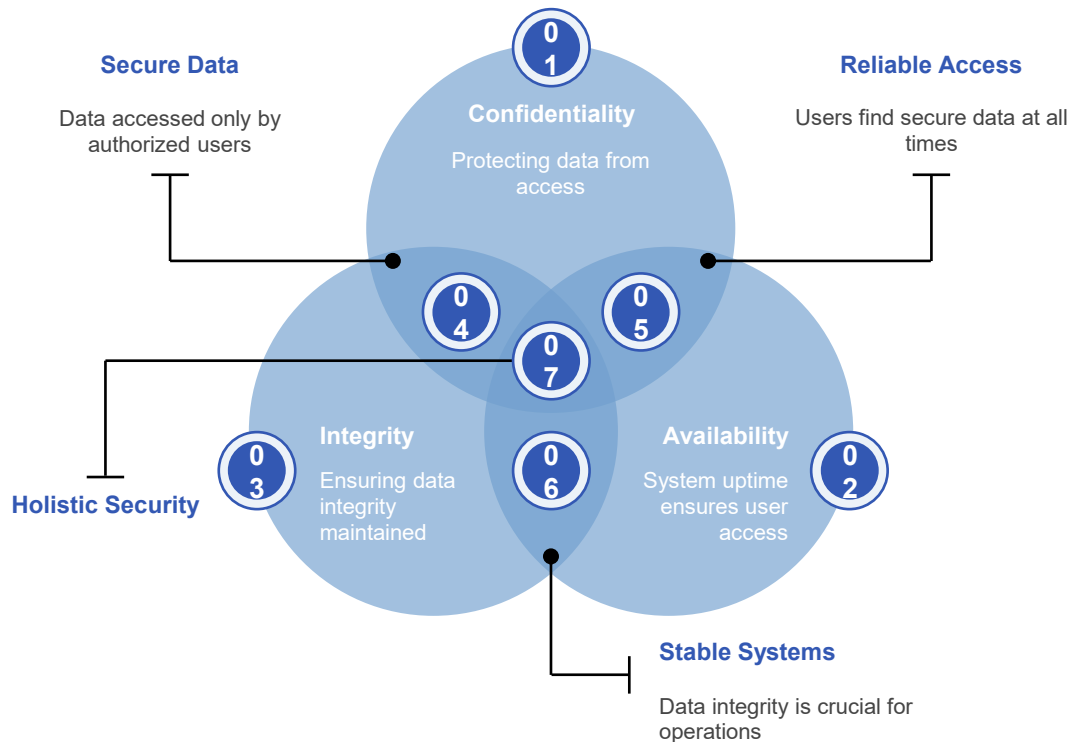
DDoS Mitigation

Traffic scrubbing, CDNs, rate limiting, cloud-based anti-DDoS services

Availability therms



Interrelationship of CIA Components



Snapshot

01

Data Breaches

85% organizations face unauthorized data access constantly.

02

System Downtime

20% revenue lost for every hour of outage.

03

Data Integrity

70% incidents linked to human error and oversight.

Challenges in Implementing CIA

Balancing Security

01

Finding the right balance between security and usability is difficult.

Employee Training

02

Regular training is necessary to maintain awareness of security best practices.

Resource Allocation

03

Funding and resources often limit comprehensive implementation of security measures.

Complexity Management

04

Managing complex security systems adds challenges in efficiency and implementation.

Technological Advances

05

Rapid tech changes create constant adaptation pressures on existing security protocols.

Compliance Issues

06

Navigating various regulations can complicate implementation efforts significantly.

Threat Landscape

07

Evolving cybersecurity threats require continuous updates to security measures.

Data Loss Risks

08

Inadequate backup strategies can lead to significant data loss during breaches.





Part 3

Trust and Trustworthiness

Understanding what we depend on vs. what we can verify

Trusted vs. Trustworthy — A Critical Distinction

In security engineering, these describe fundamentally different properties. Confusing the two is a common and dangerous mistake.



Trusted

A component we **must rely on** for the system to enforce its security policy.

Even if it has vulnerabilities, the system cannot function correctly without it.

Examples:

- Operating system kernel
- Login/authentication service
- BIOS/UEFI firmware



Trustworthy

A component we have **evidence to believe** is secure and free from exploitable flaws.

Verified through testing, certification, or cryptographic attestation.

Examples:

- TPM (Trusted Platform Module)
- Common Criteria certified HSM (Hardware Security Module)
- Formally verified microkernel (seL4)

Comparing Trusted and Trustworthy

Property	Trusted	Trustworthy
Meaning	Component we must rely on	Component proven to be reliable and secure
Basis	Defined by system architecture	Established through verification and evidence
Vulnerability	May contain vulnerabilities	Designed and tested to minimize vulnerabilities
Verification	Assumed correct (by necessity)	Verified through audits, certification, formal methods
Example	Operating system kernel	HSM that passed FIPS 140-3 certification
Risk	If compromised, entire system fails	Lower risk due to evidence-based assurance
Goal	Make trusted components trustworthy	Extend trustworthiness across the system

Key Insight: A component can be trusted without being trustworthy. The goal is to ensure every trusted component is also trustworthy — or to minimize the Trusted Computing Base (TCB).

Trust Challenges



Problem 1

**Software Bugs Causing
Security Vulnerabilities**

Poorly written code leads to errors.

Bugs can be exploited by malicious actors.



Problem 2

**Misconfigurations Increasing
System Risks**

Improper settings can expose weaknesses.

Default configurations can be insecure.



Problem 3

**User Interfaces Impacting
Trust Perception**

Complex designs can confuse users.

Poor usability may lead to distrust.



Problem 4

**Lack of Transparency in
System Operations**

Hidden processes reduce user confidence.

Users need clarity to feel secure.



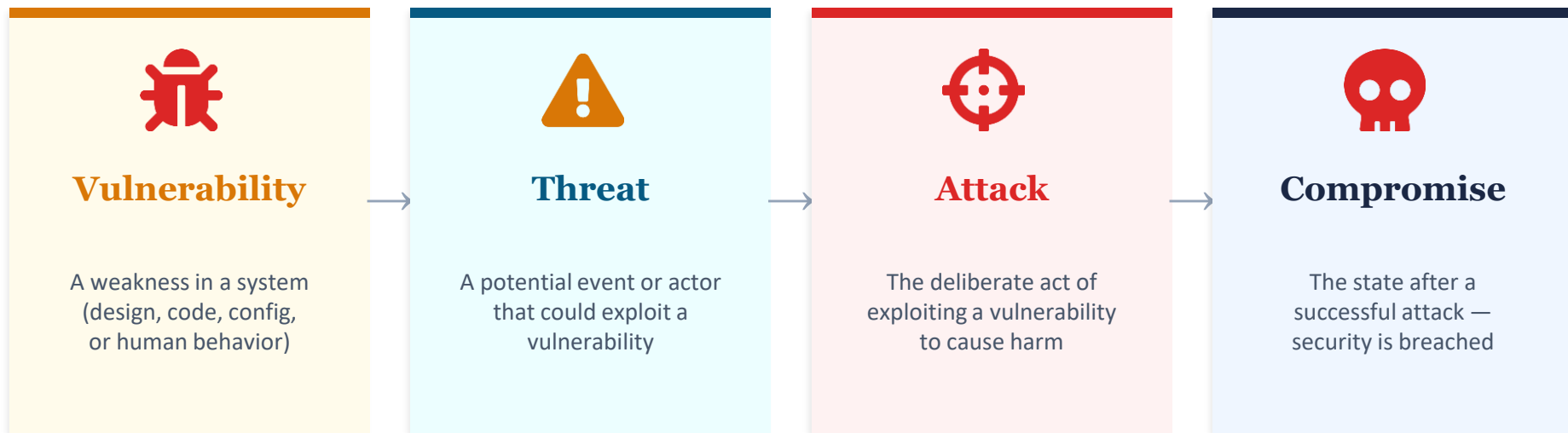
Part 4

Attack Terminology

Vulnerability, Threat, Attack, Compromise — the language of cyber risk

Attack Ontology — The Chain of Risk

Understanding the relationship between vulnerabilities, threats, attacks, and compromises is essential for risk assessment.



Vulnerabilities — Types and Examples

Software Bugs

Buffer overflows, race conditions, input validation flaws (e.g., Log4Shell CVE-2021-44228)

Misconfigurations

Default passwords, open S3 buckets, overly permissive firewall rules, debug endpoints

Design Flaws

Insufficient session management, lack of rate limiting, insecure API design

Human Factors

Weak passwords, social engineering susceptibility, poor security awareness

Supply Chain

Vulnerable third-party libraries, compromised build pipelines (e.g., SolarWinds, xz)

Zero-Day

Unknown flaws with no patch; exploited before vendors are aware; high dark market value

Threats — Who and What Threatens Our Systems?

Threat Actors

Cybercriminals



Financially motivated; ransomware, fraud, data theft for sale on dark web markets

Nation-State Actors



APT groups (APT28, APT41, Lazarus) conducting espionage, sabotage, and IP theft

Hackers



Ideologically motivated; DDoS, defacement, data leaks to promote causes

Insider Threats



Employees or contractors who misuse access (malicious or negligent)

Non-human threats: Natural disasters, hardware failures, power outages, software defects.

Current Cyber Threat Landscape (2024-2026)



AI-Powered Attacks

LLM-generated phishing, deepfake voice/video for CEO fraud, AI-assisted vulnerability discovery, automated exploit generation



Ransomware Evolution

Double/triple extortion, RaaS platforms, targeting critical infrastructure (hospitals, water, energy grids)



Supply Chain Attacks

Software supply chain (xz backdoor 2024), dependency confusion, CI/CD pipeline hijacking



Prompt Injection

Crafted inputs to LLMs/AI agents to override instructions, exfiltrate data, or manipulate outputs

Common Attack Types

Phishing / Spear Phishing

Deceptive messages tricking users into revealing credentials or installing malware

Malware

Viruses, worms, trojans, spyware, rootkits — malicious software for unauthorized access

DoS / DDoS

Overwhelming systems with traffic to make them unavailable; botnets amplify impact

Man-in-the-Middle

Intercepting communication between two parties to eavesdrop or alter data

SQL / Code Injection

Inserting malicious code into inputs to manipulate databases or execute commands

Credential Attacks

Brute force, credential stuffing (leaked password databases), password spraying

Social Engineering

Manipulating people into breaking security — pretexting, baiting, tailgating

Zero-Day Exploitation

Exploiting unknown vulnerabilities before vendor patches; extremely high impact

Compromise — When Security Fails

A compromise occurs when an attack succeeds and the security policy of a system is violated.

Indicators of Compromise (IoC)

- Unusual outbound network traffic to unknown destinations
- Unexpected account privilege escalation or new admin accounts
- Anomalous login patterns (unusual times, geolocations, failed attempts)
- Unexpected file modifications, encryption, or data exfiltration
- System performance degradation without apparent cause
- Security tool alerts or disabled antivirus/EDR agents

Consequences

Financial loss • Regulatory fines (GDPR, CCPA) • Reputation damage • Operational disruption • Legal liability



Part 5

Attack Surface and Vector

Understanding where and how attackers can strike

Attack Surface vs. Attack Vector

Attack Surface

Attack Surface

All points of contact and exposure through which an attacker can try to get in, create an effect, or extract information.

Examples: an exposed API, an admin portal, VPN, a mailbox, an employee laptop, or a supplier connection.

Attack Vector

Attack Vector

The technique or practical path the attacker uses to exploit a specific point.

Examples: phishing, a stolen token, SQL injection, a malicious package, an exploit against a public server, or prompt injection.

A simple memory rule

Surface = where you can try. Vector = how you try in practice. Attackers first map the surface and then choose a suitable vector.

Attack Surface — Where Can Attackers Strike?



The attack surface is the total set of points where an unauthorized user can try to enter or extract data from a system.



Network Surface

Open ports, exposed services, APIs, wireless access points, VPN endpoints



Application Surface

Web apps, mobile apps, APIs, microservices, third-party integrations



Human Surface

Employees, contractors, vulnerable to social engineering and credential compromise



Physical Surface

Data centers, workstations, USB ports, IoT devices, server rooms

Reducing the Attack Surface

Disable unnecessary services

Turn off unused ports, protocols, and services; remove default accounts

Least privilege principle

Grant users and processes only the minimum permissions needed

Network segmentation

Isolate sensitive systems; implement Zero Trust Network Access (ZTNA)

Patch management

Maintain up-to-date software across all endpoints; automate patching

API security

Authenticate all API calls; rate limiting; input validation; API gateways

Continuous monitoring

Attack Surface Management (ASM) tools for discovery; maintain asset inventory

Goal: Minimize the attack surface to only what is strictly required for business operations.

Attack Vectors — How Do Attackers Get In?



An attack vector is the specific path or method an attacker uses to exploit a vulnerability. The surface is "where" — the vector is "how."

Email / Phishing

Malicious attachments, spoofed links, BEC

Web Applications

XSS, CSRF, SQL injection, SSRF

Network Protocols

ARP spoofing, DNS hijacking, BGP hijacking

Malware Delivery

Drive-by downloads, malvertising, watering hole

Social Engineering

Pretexting, vishing, smishing, tailgating

Supply Chain

Compromised updates, malicious packages

Insider Access

Credential theft, privilege abuse, shadow IT

AI/LLM Exploitation

Prompt injection, data poisoning, model evasion

Attack Surface vs. Attack Vector

The attacker first maps the attack surface, then selects an attack vector to exploit a specific weakness.

Aspect	Attack Surface	Attack Vector
Definition	All possible entry points into a system	The specific method used to exploit an entry point
Analogy	All doors and windows of a building	The specific door the burglar picks to break in
Scope	Broad — the total exposure	Narrow — a single path or technique
Defense	Reduce surface (close ports, remove services)	Block vectors (filter email, validate input, patch)
Example	Web server with ports 80, 443, 22 open	Phishing email with malicious PDF attachment

Class exercise. Map the attack surface of a MTA system MAMA

What should groups of 2–3 do?

1. Identify the most sensitive assets.
2. Mark five exposure points.
3. Choose two plausible attack vectors.